

RELATÓRIO DE INVESTIGAÇÃO

ANÁLISE FORENSE DIGITAL

Papel: Equipa Investigadora

Objetivo do trabalho

Este relatório descreve a investigação forense digital que fizemos no âmbito da unidade curricular de Análise Forense Digital (ISTEC). O trabalho segue a metodologia de papel duplo «Think like a hacker, think like an investigator» (Rosa, 2025a), que se organiza em duas macro-atividades e cinco micro-etapas. Na primeira macro-atividade, cada grupo constrói um cenário de ataque, escondendo dados e apagando vestígios. Na segunda, investiga o cenário que outro grupo construiu. Esta troca de papéis, a que o autor chama *dual-role*, obriga-nos a pensar primeiro como quem ataca e depois como quem investiga. É essa alternância que nos permite acompanhar um incidente de ponta a ponta: desde a forma como os dados são ocultados até à recolha e análise da prova (Rosa, 2025a).

Este documento corresponde à segunda macro-atividade, «Think like an investigator». Situa-se nas micro-etapas de troca das imagens periciais e de análise e apresentação dos resultados. Recebemos uma imagem pericial produzida por outro grupo, com o objetivo de identificar e documentar comportamentos suspeitos ou maliciosos e reconstruir a narrativa do incidente.

A análise forense digital corresponde à aquisição, preservação, identificação, extração, restauro, análise e documentação de evidências computacionais (Kruse & Heiser, 2001, citado por Rosa, 2025a). Verificámos a integridade da evidência, examinámos a imagem, recuperámos ficheiros eliminados, estudámos metadados e registos, identificámos técnicas de ocultação e formulámos hipóteses, que depois procurámos validar com as evidências recolhidas.

Não pretendemos demonstrar a culpa de alguém, mas explicar o estado em que os artefactos digitais se encontram, sustentando cada afirmação em prova documentada. Para ter valor num processo, a prova digital tem de ser admissível, autêntica, completa, fiável e credível. O critério da fiabilidade obriga-nos a documentar todo o manuseamento da evidência, para que ninguém a possa contestar mais tarde. Por isso seguimos as orientações do NIST SP 800-86 (NIST, 2006) e da ISO/IEC 27037:2012 (ISO/IEC, 2012), registando os hashes em cada extração.

As duas normas têm enfoques diferentes. O NIST SP 800-86 põe a ênfase na resposta a incidentes e em como integrar as técnicas forenses nesse processo. A ISO/IEC 27037:2012 centra-se na recolha e na preservação da prova digital, com vista à sua utilização em tribunal (Rosa, 2025a). São enfoques complementares, e foi por isso que as adotámos em conjunto.

Ferramentas utilizadas

Usámos ferramentas gratuitas ou de código aberto, repartidas por dois ambientes de trabalho: um posto Windows e uma máquina virtual Kali Linux.

Ferramenta	Ambiente	Aplicação na investigação
FTK Imager 8.2.0.59	Windows	Verificação de integridade da imagem recebida (MD5/SHA-1)
Autopsy 4.23.1	Windows	Processamento da imagem, deteção de extensões trocadas, triagem de ficheiros eliminados e pesquisa por palavras-chave (Keyword Search)
PowerShell (Get-FileHash) / sha256sum	Windows / Kali Linux	Registo de hashes SHA-256 dos artefactos extraídos
ewf-tools (ewfmount, ewfverify)	Kali Linux	Montagem dos segmentos EWF e reverificação independente da integridade
The Sleuth Kit (fsstat, icat)	Kali Linux	Caracterização do sistema de ficheiros e extração de ficheiros pelo endereço de metadados
foremost	Kali Linux	Carving por assinatura, como via redundante de recuperação
binwalk	Kali Linux	Deteção de conteúdo embebido (polyglot)
exiftool	Kali Linux	Triagem de metadados das imagens
file	Kali Linux	Identificação do tipo real dos ficheiros por assinatura de cabeçalho
dd	Kali Linux	Extração de payload por deslocamento (offset)
strings	Kali Linux	Pesquisa de cadeias de texto na imagem
base64	Kali Linux	Descodificação do ficheiro de instruções ofuscado
unzip / xmllint	Kali Linux	Exame da estrutura interna dos ficheiros OOXML

Índice

Objetivo do trabalho.....	1
Ferramentas utilizadas.....	2
1. Verificação de integridade da imagem pericial.....	4
1.1. Receção da evidência.....	4
1.2. Dados da aquisição (realizada pelo grupo atacante).....	4
1.3. Verificação de integridade pela equipa investigadora.....	4
Enquadramento normativo.....	5
2. Exame da imagem e deteção de artefacto ocultado.....	6
2.1. Processamento no Autopsy.....	6
2.2. Artefacto suspeito.....	6
2.3. Extração e preservação do artefacto.....	7
2.4. Conteúdo do artefacto.....	7
3. Análise de metadados do artefacto (OOXML).....	8
4. Triagem de esteganografia e ocultação (81 imagens).....	9
4.1. Triagem de metadados (exiftool).....	10
4.2. Triagem de dados embebidos (binwalk).....	10
4.3. Extração do polyglot (ficheiro 60).....	11
4.4. Ficheiros «-fakepng» (WebP renomeados).....	13
4.5. Síntese das técnicas de ocultação.....	13
5. Registo de evidências (prints).....	14
6. Estado das diligências.....	14
7. Recuperação de ficheiros eliminados e automação de exfiltração.....	15
7.1. Filtragem temporal por atributos.....	15
7.2. Confirmação do Artefacto 1 na linha temporal.....	16
7.3. Scripts de designação sugestiva (recolha de credenciais e dados).....	16
7.4. Ficheiro de instruções ofuscado (Base64).....	17
7.5. Descodificação do ficheiro de instruções e registo de exfiltração.....	18
7.6. Validação redundante por carving de assinatura (foremost).....	19
7.7. Interface de controlo de acesso com credencial embutida.....	20
7.8. Triagem completa dos ficheiros eliminados e reclassificação dos scripts.....	21
8. Consolidação e hipótese de trabalho.....	23
9. Conclusão.....	24
10. Avaliação crítica.....	25
10.1. Eficácia das técnicas de ocultação.....	25
10.2. Dificuldades encontradas durante a investigação.....	25
10.3. Limitações da análise.....	26
11. Reflexão.....	26
12. Referências.....	27
13. Identificação e assinaturas.....	27

1. Verificação de integridade da imagem pericial

1.1. Receção da evidência

Recebemos uma pen drive do grupo atacante com uma imagem pericial em formato Expert Witness (EWF / .E01), dividida em quatro ficheiros (Imagem AFD.E01 a .E04, cerca de 4,52 GB no total), acompanhada do relatório de aquisição (Imagem AFD.E01.txt).

1.2. Dados da aquisição (realizada pelo grupo atacante)

O grupo atacante (VC, GB, AG, JS) criou a imagem pericial com o Exterro FTK Imager 8.2.0.59, antes de no-la entregar. Transcrevemos os valores desta ficha do relatório de aquisição que produziram.

Campo	Valor
Número do caso	01
Número da evidência	01
Descrição	Main evidence folder
Tipo de fonte	Lógica: dispositivo removível
Dimensão da fonte	32 768 MB
Bytes por setor	512
Contagem de setores	67 108 864
Início da aquisição	2026-07-02 20:12:58
Fim da aquisição	2026-07-02 20:46:45

Hashes de referência (aquisição):

MD5: 2e7b64e3636df11b777eb59b05dfe3c5

SHA-1: 38a6dacf80df61b4e939be4927ee9a820b09bf95

Há dois aspetos a reter nesta ficha. O primeiro é que o tipo de fonte é lógico, e não físico: a aquisição copiou o conteúdo do dispositivo removível, não a totalidade dos seus setores. Estruturas internas do sistema de ficheiros que residem fora da área de dados, como a \$MFT ou as hives do registo, não estão, por isso, disponíveis para exame, e essa limitação condiciona várias das diligências descritas mais à frente. O segundo é que o grupo atacante fez a verificação na altura da aquisição, e os valores Computed, Stored e Report coincidem (MD5 e SHA-1 verified). Isso demonstra que a imagem estava íntegra quando foi criada, mas nada diz sobre o que possa ter acontecido entre a aquisição e a entrega.

1.3. Verificação de integridade pela equipa investigadora

Procedimento: File > Add Evidence Item > Image File — seleção do segmento .E01 — Verify Drive/Image.

Recalculámos os valores em vez de nos limitarmos a aceitar os que constavam do relatório de aquisição, porque só um cálculo feito por nós, sobre os ficheiros que temos em mãos, cobre o intervalo entre a produção da imagem e a sua receção. Usámos os algoritmos MD5 e SHA-1, que são os que o FTK Imager grava no cabeçalho do formato EWF.

Hash	Valor de referência	Valor recalculado	Corresponde?
MD5	2e7b64e3...dfe3c5	2e7b64e3...dfe3c5	Sim
SHA-1	38a6dacf...09bf95	38a6dacf...09bf95	Sim

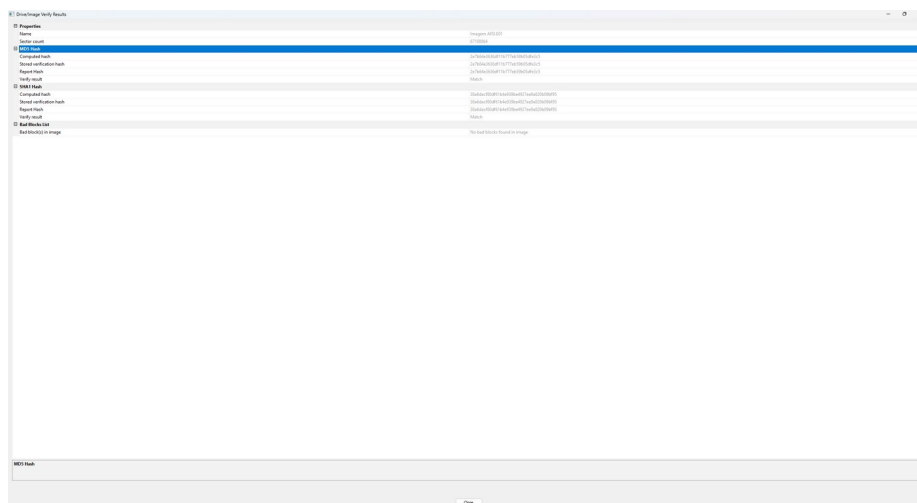


Figura 1. FTK Imager: resultado da verificação (MD5 e SHA-1: Match; sem bad blocks).

Resultados adicionais: não detetámos setores danificados (Bad blocks: No bad blocks found in image). Contagem de setores confirmada: 67 108 864.

Conclusão: A verificação confirmou a integridade da imagem. Os valores MD5 e SHA-1 que recalculámos correspondem aos hashes de aquisição (Verify result: Match), o que indica que a imagem que analisámos corresponde, bit a bit, àquela cujos hashes o grupo atacante registou no relatório de aquisição. Assim, documentámos o elo entre a aquisição e o exame.

Enquadramento normativo

Um dos princípios da análise forense é que o exame não deve ser feito sobre o dispositivo original, salvo em casos excepcionais (INTERPOL, 2021): trabalha-se antes sobre uma cópia, para não comprometer a integridade da evidência. Essa cópia tem de ser uma réplica exata, bit a bit, do dispositivo de origem, independentemente do conteúdo que lá esteja. A evidência que recebemos é uma imagem pericial em formato EWF, gerada com o FTK Imager, ferramenta recomendada nesta metodologia precisamente para esta etapa.

Uma cópia só tem valor se conseguirmos demonstrar que é fiel ao original. A função de hash produz um valor que sintetiza um conjunto de dados, e é aquilo a que o guia da INTERPOL chama a «impressão digital» dos dados. Quando se copia um dispositivo original, calcula-se o hash da origem e o hash do destino, e a verificação consiste em comparar os dois valores, que têm de ser idênticos. Foi esse o procedimento que seguimos no ponto 1.3, e o resultado foi de correspondência.

Este procedimento responde às exigências das duas normas que adotámos. A ISO/IEC 27037:2012 (ISO/IEC, 2012) trata da identificação, recolha, aquisição e preservação da prova digital, e é a norma que sustenta os requisitos de integridade e de rastreabilidade. O NIST SP 800-86 (NIST, 2006) enquadra esta operação nas fases de recolha e exame do processo forense.

A confirmação da integridade é também o que nos permite afirmar que a cadeia de custódia se mantém. A cadeia de custódia documenta quem teve a evidência na sua posse, quando, e o que lhe fez, desde a apreensão até à análise (Rosa, 2025b). Sem essa documentação, a prova pode ser contestada, porque deixa de ser possível demonstrar que não foi alterada pelo caminho. Fizemos a verificação por hash à chegada e antes de qualquer manipulação, o que permite documentar que a imagem examinada não sofreu alterações desde a sua produção pelo grupo atacante.

2. Exame da imagem e deteção de artefacto oculto

2.1. Processamento no Autopsy

Importámos a imagem pericial no Autopsy 4.23.1 (caso «AFD_Investigacao», fonte de dados única). O processamento (ingest) identificou 81 imagens, 3 arquivos, 608 ficheiros eliminados e assinalou automaticamente 1 artefacto em «Extension Mismatch Detected» / «Suspicious Items».

um arquivo ZIP com uma estrutura interna definida, e a pasta docProps faz parte dessa estrutura, pelo que a sua presença identifica o ficheiro como documento Office (OOXML). Era uma folha de cálculo Excel gravada com a extensão .png, numa pasta de imagens genuínas.

2.3. Extração e preservação do artefacto

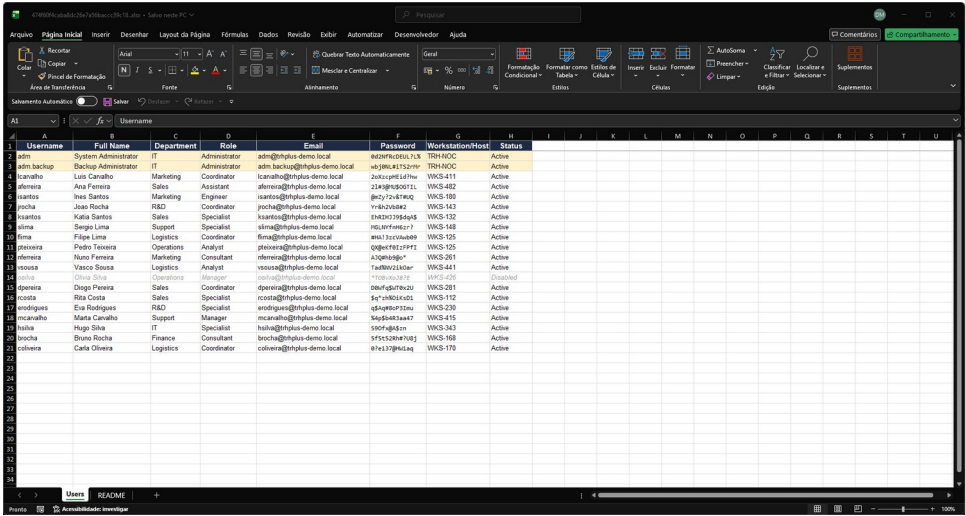
Extraímos o ficheiro da imagem com o Autopsy (Extract File) para a pasta do caso, e renomeámo-lo para .xlsx só para efeitos de análise; na imagem, o nome original continua .png. A seguir calculámos os hashes do artefacto, para garantir a sua rastreabilidade individual (ISO/IEC 27037).

Hash do artefacto extraído	Valor
SHA-256	780EAB3894AC1CE478765A0FAB50381ABC47E2C1E2363FE2DED5A28FAF055654
MD5	E5BE25C8B4441D3E93CAE981AE4CB07F

Figura 4. PowerShell Get-FileHash: SHA-256 e MD5 do artefacto extraído.

2.4. Conteúdo do artefacto

A folha de cálculo é composta por duas abas: «Users» e «README». A aba «Users» contém uma tabela de credenciais do domínio trhplus-demo.local, com 20 contas (linhas 2 a 21). Observámos ainda que as contas «pteixeira» e «flima» partilham a mesma estação (WKS-125) e que a conta «osilva» (Operations Manager, WKS-426) se encontra Disabled, ao contrário das restantes (Active).



Username	Full Name	Department	Role	Email	Password	Workstation/Host	Status
adm	System Administrator	IT	Administrator	adm@trhplus-demo.local	adm@trhplus.local	TRH-H00C	Active
adm.backup	Backup Administrator	IT	Administrator	adm.backup@trhplus-demo.local	w8j9ML4T52m9	TRH-H00C	Active
Beralho	Luís Beralho	Marketing	Coordinator	lberalho@trhplus-demo.local	2ab2up8L7fhw	WKS-411	Active
pteixeira	Ana Ferreira	Sales	Assistant	alferreira@trhplus-demo.local	2149j8d80T1L	WKS-482	Active
Santos	Inês Santos	Marketing	Engineer	isantos@trhplus-demo.local	8mcy12-67WQ	WKS-188	Active
Pincha	João Pincha	R&D	Coordinator	jpincha@trhplus-demo.local	Y+h305d84	WKS-143	Active
Ksantos	Karla Santos	Sales	Specialist	ksantos@trhplus-demo.local	1m2d3795d9d5	WKS-132	Active
Sima	Sergio Lima	Support	Specialist	slima@trhplus-demo.local	h2Lw7Fm6z1	WKS-148	Active
Tima	Filipe Lima	Logistics	Coordinator	flima@trhplus-demo.local	8mU1300d4d8b	WKS-125	Active
pteixeira	Pedro Teixeira	Operations	Analyst	ppteixeira@trhplus-demo.local	q9q8Fm21PF1	WKS-125	Active
Almeida	Nuno Almeida	Marketing	Consultant	nalmeida@trhplus-demo.local	20p9d8g7	WKS-281	Active
Sousa	Vasco Sousa	Logistics	Analyst	vsousa@trhplus-demo.local	7w8f8v23d0w	WKS-441	Active
Almeida	Diogo Almeida	Operations	Manager	dalmeida@trhplus-demo.local	1m2Lm2k27	WKS-426	Disabled
Almeida	Diogo Almeida	Sales	Coordinator	dalmeida@trhplus-demo.local	2m7d6k7d2d	WKS-281	Active
Rosta	Rita Costa	Sales	Specialist	rcosta@trhplus-demo.local	5d4*9m80v4d5	WKS-112	Active
erodrigues	Eva Rodrigues	R&D	Specialist	erodrigues@trhplus-demo.local	q54v6t8725u	WKS-239	Active
Carvalho	Maria Carvalho	Support	Manager	mcarvalho@trhplus-demo.local	5ed3d437a47	WKS-415	Active
halva	Hugo Silva	IT	Specialist	halva@trhplus-demo.local	180Fq8d0n	WKS-343	Active
Pincha	João Pincha	Finance	Consultant	jpincha@trhplus-demo.local	17F512d4h143	WKS-168	Active
coliveira	Carla Oliveira	Logistics	Coordinator	coliveira@trhplus-demo.local	6h13178k6d4q	WKS-179	Active

Figura 5. Aba «Users»: 20 contas com credenciais em texto claro.

3. Análise de metadados do artefacto (OOXML)

Para ver os metadados internos sem abrir o documento no Excel (o que poderia alterar metadados sem querer ou correr macros), copiámos o artefacto, renomeámos a cópia para .zip e descompactámos a estrutura OOXML. Analisámos os ficheiros docProps/app.xml e docProps/core.xml.

Metadado	Valor
Aplicação geradora (app.xml)	Microsoft Excel Compatible / Openpyxl 3.1.5
Autor / criador (core.xml)	openpyxl
Data de criação interna	2026-06-25T17:58:49Z
Data de modificação interna	2026-06-25T17:58:49Z

Metadado	Valor
----------	-------

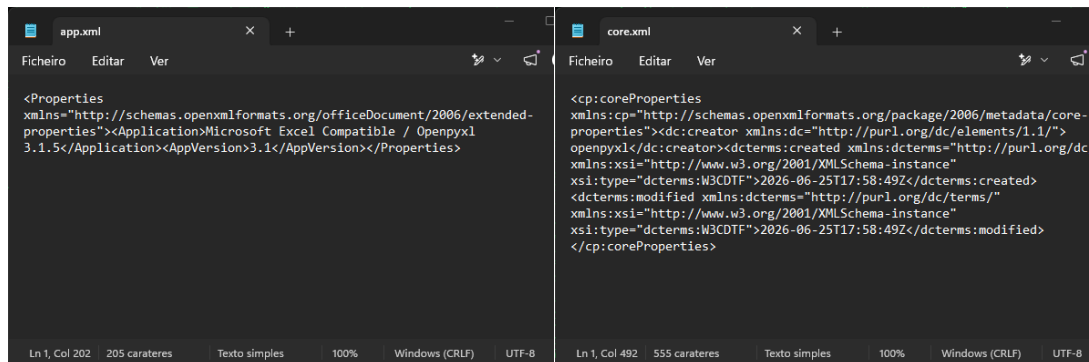


Figura 6. app.xml: gerado por Openpyxl 3.1.5.

Figura 7. core.xml: creator «openpyxl»; created = modified (mesmo segundo).

Os metadados indicam que o ficheiro não foi feito por uma pessoa, mas gerado por código, através da biblioteca Python openpyxl. As datas de criação e de modificação coincidem ao segundo (2026-06-25T17:58:49Z), o que aponta para uma única operação de escrita automática: num ficheiro editado manualmente, a modificação seria posterior à criação. Este padrão é consistente com um artefacto de exfiltração de credenciais produzido por script.

Confirmámos isto por outra via, no nó Data Artifacts — Metadata do Autopsy, sem ferramentas externas: os mesmos campos (Owner, Program Name e datas coincidentes) aparecem aí tirados diretamente do artefacto, com o caminho de origem na imagem (/img_Imagem AFD.E01/imagens/ac6/474f60f4caba8dc26e7a56bacc39c18.png). Chegar ao mesmo resultado por duas vias diferentes reforça a conclusão de que a autoria é programática.

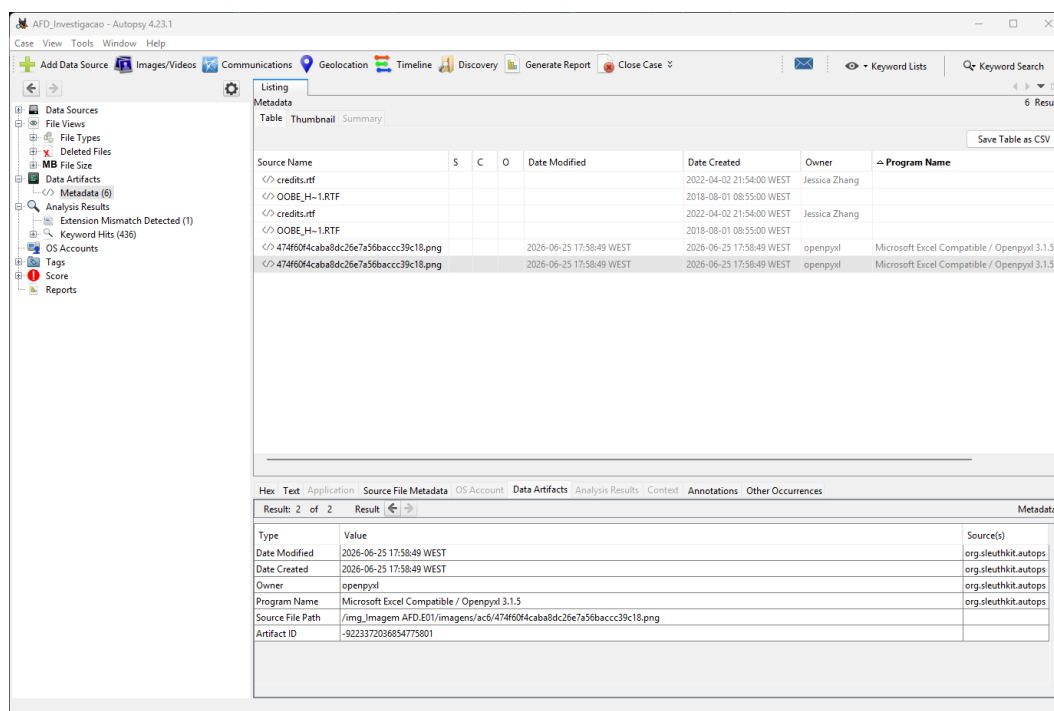


Figura 8. Autopsy (Data Artifacts): Owner «openpyxl», Program Name «Openpyxl 3.1.5» e caminho de origem do artefacto: confirmação independente da autoria programática.

4. Triagem de esteganografia e ocultação (81 imagens)

Exportámos as 81 imagens do Autopsy para análise em ambiente isolado (Kali Linux). Fizemos a transferência por disco externo em modo Offline no anfitrião, com passthrough direto para a máquina virtual, preservando o isolamento (air-gap) e a cadeia de custódia.

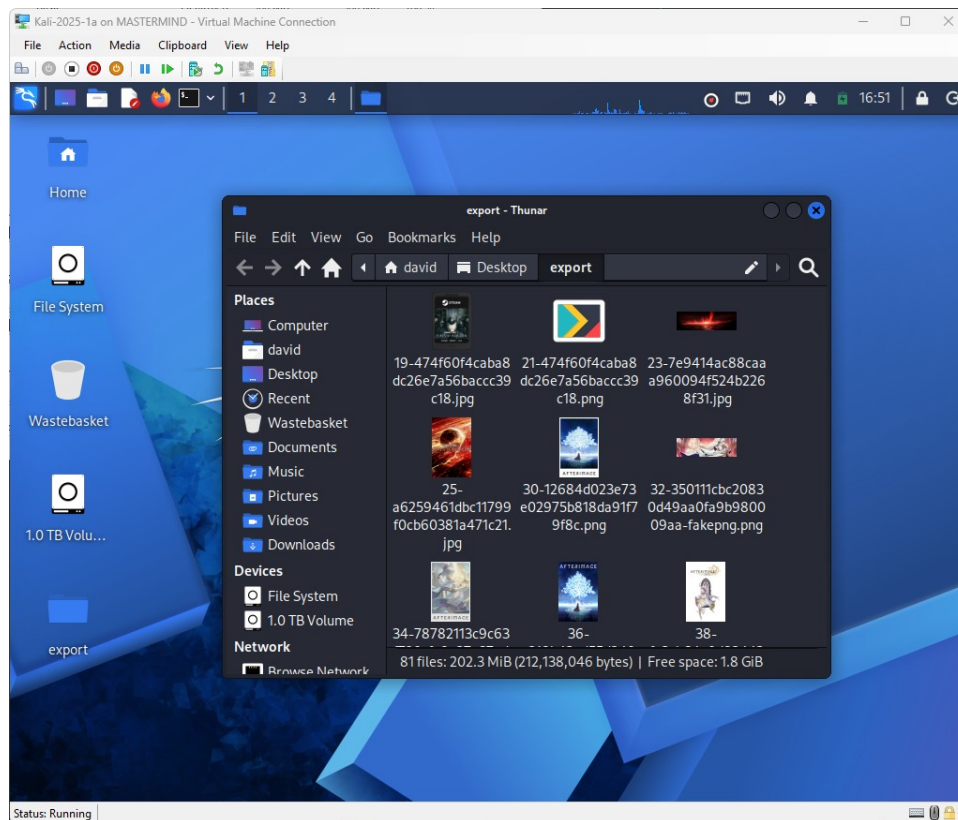


Figura 9. Kali/Thunar: lote de 81 ficheiros exportados (nota o ficheiro «fakepng» já visível no nome).

4.1. Triagem de metadados (exiftool)

Corremos um varrimento em massa com o exiftool sobre as 81 imagens, à procura de anomalias, comentários ou dados escondidos na camada de metadados. O resultado foi negativo: não encontrámos nenhuma flag nem payload nessa camada.

```
david@kali: ~/Desktop/export
└─(david@ kali) -[~/Desktop/export]
└─$ cd ~/Desktop/export
exiftool -Comment -UserComment -XPCComment -Description . 2>/dev/null | grep -v "^====" | grep -v "^$"
1 directories scanned
81 image files read

└─(david@ kali) -[~/Desktop/export]
└─$ exiftool -a -u -g1 *350111cb* | head -20
---- ExifTool ----
ExifTool Version Number      : 13.50
---- System ----
File Name                    : 32-350111cbc20830d49aa0fa9b98009aa-fakepng.png
Directory                   : .
File Size                    : 26 MB
File Modification Date/Time  : 2026:07:06 16:40:32+01:00
File Access Date/Time       : 2026:07:09 12:38:58+01:00
File Inode Change Date/Time  : 2026:07:06 16:51:37+01:00
File Permissions             : -rwxr-xr-x
---- File ----
File Type                    : Extended WEBP
File Type Extension          : webp
MIME Type                    : image/webp
---- RIFF ----
WebP Flags                   : Animation, Alpha
Image Width                  : 1920
Image Height                 : 620
Background Color             : 255 255 255 255
Animation Loop Count         : inf
```

Figura 10. Kali (exiftool): varrimento das 81 imagens sem qualquer comentário ou descrição na camada de metadados; em baixo, identificação de um ficheiro «fakepng» como contentor RIFF/WebP.

4.2. Triagem de dados embebidos (binwalk)

A seguir, o binwalk mostrou que a maior parte dos «achados» (JBOOT, ZBOOT, MySQL MISAM, Cisco IOS, StuffIt) eram falsos positivos: sequências de dados zlib comprimidos que coincidem com assinaturas de firmware, o que é comum em imagens PNG legítimas. Depois de filtrar esse ruído, restaram três categorias de achados reais:

```

david@kali: ~/Desktop/export
Target File: /home/david/Desktop/export/21-474f60f4caba8dc26e7a56bacc39c18.png
MD5 Checksum: e5be25c8b4441d3e93cae981ae4cb07f
Signatures: 436

-----
DECIMAL    HEXADECIMAL  DESCRIPTION
-----
0          0x0          Zip archive data, at least v2.0 to extract, compressed size: 149, uncompressed size: 205, name: docPro
ps/app.xml
195        0xC3         Zip archive data, at least v2.0 to extract, compressed size: 240, uncompressed size: 555, name: docPro
ps/core.xml
482        0x1E2        Zip archive data, at least v2.0 to extract, compressed size: 1552, uncompressed size: 10140, name: xl/
theme1.xml
--
Target File: /home/david/Desktop/export/58-1107bcdc49d29e521a91da172e408fea-fakepng.png
MD5 Checksum: b9cebec57114d0715b5ea89c244a7fb3
Signatures: 436

-----
DECIMAL    HEXADECIMAL  DESCRIPTION
-----
1308312    0x13F698     MySQL MISAM compressed data file Version 7
5240435    0x4FF673     MySQL MISAM index file Version 11
17624120   0x10CEC38    JBOOT STAG header, image id: 15, timestamp 0xBF29ED1B, image size: 349464461 bytes, image JBOOT checks
um: 0x561, header JBOOT checksum: 0x7518
--
Target File: /home/david/Desktop/export/60-35d7fa46a5d058ab18ca95260a0ddd2e.png
MD5 Checksum: 05341776a43392124dc1f902f8d2a00a
Signatures: 436

-----
DECIMAL    HEXADECIMAL  DESCRIPTION
-----
0          0x0          JPEG image data, JFIF standard 1.01
775978     0xBD72A      Zip archive data, at least v2.0 to extract, name: xl/_rels/workbook.xml.rels
776290     0xBD862      Zip archive data, at least v2.0 to extract, name: xl/workbook.xml

(david@kali) - [~/Desktop/export]
$

```

Figura 11. Kali (binwalk): as três categorias de achados reais confirmadas — ZIP/OOXML no offset 0 do ficheiro «21-...c39c18.png» (Artefacto 1), falsos positivos de firmware (MySQL MISAM, JBOOT STAG) no «fakepng» «58-...fea-fakepng.png», e a transição JPEG → ZIP no offset 0xBD72A do polyglot «60-...ddd2e.png».

Categoria	Ficheiros	Natureza
Artefacto já identificado	21-...c39c18.png	ZIP/OOXML desde o offset 0 (dump de credenciais da secção 2)
Ficheiros nomeados «-fakepng»	32, 58, 153, 157, 254	Sem assinatura PNG no offset 0: ficheiros disfarçados
Polyglot JPEG + XLSX	60-...0ddd2e.png	JPEG real com um .xlsx completo anexado no fim (offset 0xBD72A)

4.3. Extração do polyglot (ficheiro 60)

O ficheiro «60-35d7fa46a5d058ab18ca95260a0ddd2e.png» apresenta a assinatura JPEG no início e um arquivo OOXML anexado a partir do offset 0xBD72A (775978 em decimal). Calculámos o hash do ficheiro-fonte antes de qualquer manipulação, e o do payload depois de recortado, para que ambos os objetos tenham rastreabilidade própria.

Um offset é apenas a posição de um byte dentro do ficheiro, contada a partir do início. O valor 0xBD72A está escrito em hexadecimal, que é a notação usada pelas ferramentas de análise, e corresponde ao byte 775978. Interessa-nos porque é ali que um ficheiro acaba e outro começa. Um ficheiro JPEG termina sempre com os bytes FF D9, o marcador de fim de imagem, e nada deveria existir depois dele. Neste caso existe: imediatamente a seguir aparece a sequência 50 4B 03 04, que é a assinatura de um arquivo ZIP. A posição desse PK é o offset a partir do qual recortámos o conteúdo anexado.

```

david@kali: ~
(david@kali) - [~]
$ sudo icat /mnt/ewf/ewf1 997389 > /tmp/art2.bin
sha256sum /tmp/art2.bin
xxd -s 0xBD720 -l 48 /tmp/art2.bin
44bf64350771a4b1cd98c03ad6e682d5a68f15a36d508bedace16724ddd336a2 /tmp/art2.bin
000bd720: d9 76 56 3d 0f 61 f7 e3 ff d9 50 4b 03 04 14 00  ..v..a...PK...
000bd730: 08 08 08 00 54 90 d9 5c 00 00 00 00 00 00 00  ....T..
000bd740: 00 00 00 00 1a 00 00 00 78 6c 2f 5f 72 65 6c 73  ....xl/_rels

(david@kali) - [~]
$

```

Figura 12. Kali (icat / sha256sum / xxd): SHA-256 do polyglot e transição do marcador de fim de JPEG (FF D9) para a assinatura ZIP (50 4B 03 04) no offset 0xBD72A.

O payload extraído é um arquivo OOXML válido: 21 ficheiros internos, incluindo três folhas (sheet1/2/3.xml), dois gráficos (chart1/2.xml), desenhos e um docProps/custom.xml. Ao contrário do primeiro artefacto (que era um despejo de credenciais), este é um modelo orçamental empresarial funcional. As folhas têm 12 colunas mensais e categorias de despesa, com valores por célula, fórmulas SUM ativas para os totais de linha e coluna e moeda em EUR (€).

Elemento	Valor
SHA-256 do ficheiro-fonte	44bf64350771a4b1cd98c03ad6e682d5a68f15a36d508bedace16724ddd336a2
SHA-256 do payload extraído	885d07cab942e94d2f96f35af3e2e7f5d7966b6412a7c80c7f028340ae2c4411
Offset do payload	0xBD72A (775978)
Método de extração	dd if=... of=payload_60.xlsx bs=1 skip=775978
Dimensão extraída	17 592 bytes (≈18 KB)

```

(david@kali)~/Desktop/export
$ cat extract_60/xl/worksheets/sheet1.xml
cat: extract_60/xl/worksheets/sheet1.xml: No such file or directory

(david@kali)~/Desktop/export
$ cat extract_60/xl/worksheets/sheet1.xml
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<worksheet xmlns="http://schemas.openxmlformats.org/spreadsheetml/2006/main" xmlns:r="http://schemas.openxmlformats.org/officeDocument/2006/relationships" xmlns:xdr="http://schemas.openxmlformats.org/drawingml/2006/spreadsheetDrawing" xmlns:x14="http://schemas.microsoft.com/office/spreadsheetml/2009/9/main" xmlns:xr2="http://schemas.microsoft.com/office/spreadsheetml/2015/revision2" xmlns:mc="http://schemas.openxmlformats.org/markup-compatibility/2006">
  <sheetPr filterMode="false">
    <pageSetUpPr fitToPage="false">
      <sheetPr>
        <dimension ref="A1:N15">
          <sheetViews>
            <sheetView showFormulas="false" showGridLines="false" showRowColHeaders="true" showZeros="true" rightToLeft="false" tabSelected="true" showOutlineSymbols="true" defaultGridColor="true" views="normal" topLeftCell="A1" colorId="64" zoomScale="100" zoomScaleNormal="100" zoomScalePageLayoutViews="100" workbookViewId="0">
            <pane xSplit="1" ySplit="1" topLeftCell="B2" activePane="bottomRight" state="frozen">
              <selection pane="topLeft" activeCell="A1" activeCellId="0" sqref="A1">
              <selection pane="topRight" activeCell="B1" activeCellId="0" sqref="B1">
              <selection pane="bottomLeft" activeCell="A2" activeCellId="0" sqref="A2">
              <selection pane="bottomRight" activeCell="A1" activeCellId="0" sqref="A1">
            </sheetView>
          </sheetViews>
          <sheetFormatPr defaultColWidth="8.6796875" defaultRowHeight="15" zeroHeight="false" outlineLevelRow="0" outlineLevelCol="0">
            <sheetFormatPr>
              <cols>
                <col collapsed="false" customWidth="true" hidden="false" outlineLevel="0" max="1" min="1" style="0" width="32">
                <col collapsed="false" customWidth="true" hidden="false" outlineLevel="0" max="14" min="2" style="0" width="11">
              </cols>
            </sheetFormatPr>
            <sheetData>
              <row r="1" customFormat="false" ht="19.5" hidden="false" customHeight="true" outlineLevel="0" collapsed="false">
                <c r="A1" s="1" t="s"><v>0</v></c>
                <c r="B1" s="1" t="s"><v>1</v></c>
                <c r="C1" s="1" t="s"><v>2</v></c>
                <c r="D1" s="1" t="s"><v>3</v></c>
                <c r="E1" s="1" t="s"><v>4</v></c>
                <c r="F1" s="1" t="s"><v>5</v></c>
                <c r="G1" s="1" t="s"><v>6</v></c>
                <c r="H1" s="1" t="s"><v>7</v></c>
                <c r="I1" s="1" t="s"><v>8</v></c>
                <c r="J1" s="1" t="s"><v>9</v></c>
                <c r="K1" s="1" t="s"><v>10</v></c>
                <c r="L1" s="1" t="s"><v>11</v></c>
                <c r="M1" s="1" t="s"><v>12</v></c>
                <c r="N1" s="1" t="s"><v>13</v></c>
              </row>
              <row r="2" customFormat="false" ht="15" hidden="false" customHeight="false" outlineLevel="0" collapsed="false">
                <c r="A2" s="2" t="s"><v>14</v></c>
                <c r="B2" s="3" t="n"><v>4185</v></c>
                <c r="C2" s="3" t="n"><v>4171</v></c>
                <c r="D2" s="3" t="n"><v>4213</v></c>
                <c r="E2" s="3" t="n"><v>4164</v></c>
                <c r="F2" s="3" t="n"><v>4203</v></c>
                <c r="G2" s="3" t="n"><v>4189</v></c>
                <c r="H2" s="3" t="n"><v>4163</v></c>
                <c r="I2" s="3" t="n"><v>4201</v></c>
                <c r="J2" s="3" t="n"><v>4161</v></c>
                <c r="K2" s="3" t="n"><v>4194</v></c>
                <c r="L2" s="3" t="n"><v>4164</v></c>
                <c r="M2" s="3" t="n"><v>4166</v></c>
                <c r="N2" s="4" t="n"><f>=SUM(B2:M2)</f></c>
              </row>
              <row r="3" customFormat="false" ht="15" hidden="false" customHeight="false" outlineLevel="0" collapsed="false">
                <c r="A3" s="2" t="s"><v>15</v></c>
                <c r="B3" s="3" t="n"><v>871</v></c>
                <c r="C3" s="3" t="n"><v>839</v></c>
                <c r="D3" s="3" t="n"><v>657</v></c>
                <c r="E3" s="3" t="n"><v>569</v></c>
                <c r="F3" s="3" t="n"><v>560</v></c>
                <c r="G3" s="3" t="n"><v>560</v></c>
                <c r="H3" s="3" t="n"><v>560</v></c>
                <c r="I3" s="3" t="n"><v>560</v></c>
                <c r="J3" s="3" t="n"><v>560</v></c>
                <c r="K3" s="3" t="n"><v>560</v></c>
                <c r="L3" s="3" t="n"><v>560</v></c>
                <c r="M3" s="3" t="n"><v>560</v></c>
                <c r="N3" s="3" t="n"><v>560</v></c>
              </row>
            </sheetData>
          </worksheet>
        </sheetPr>
      </pageSetUpPr>
    </sheetPr>
  </worksheet>
</xml>
  
```

Figura 13. sheet1.xml do polyglot: orçamento com valores e fórmulas SUM ativas.

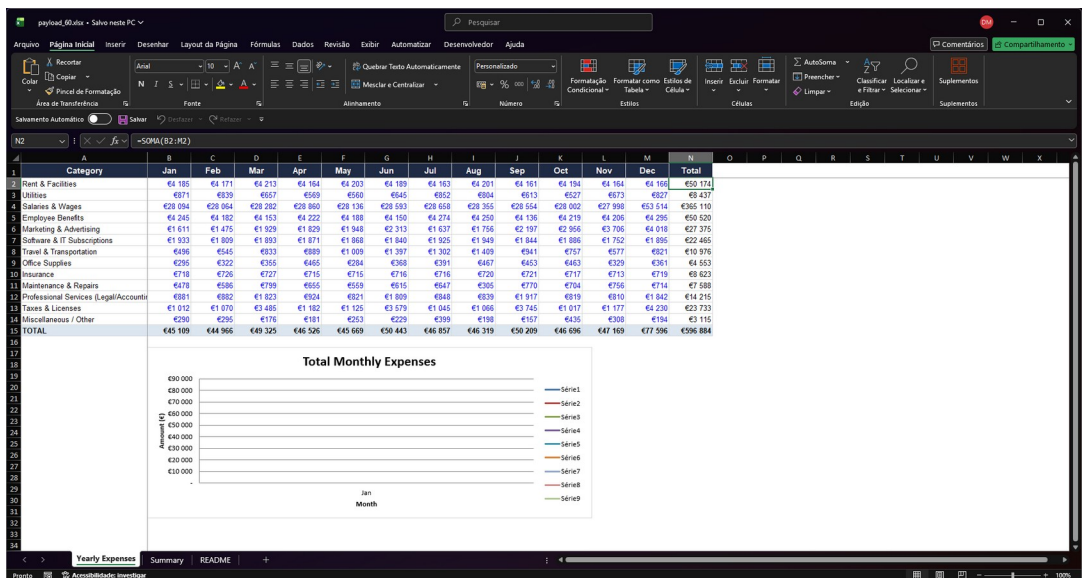


Figura 14. Payload extraído aberto no Excel: célula N2 com a fórmula =SOMA(B2:M2) ativa e o total anual por categoria.

Nota metodológica: extrair com dd a partir do offset exato produz um arquivo ZIP íntegro do primeiro ao último byte. Preferimos este método ao carving automático (binwalk -e) porque, em ficheiros polyglot, o carving pode cortar no sítio errado.

4.4. Ficheiros «fakepng» (WebP renomeados)

O binwalk sinalizou cinco ficheiros com o sufixo «-fakepng» (índices 32, 58, 153, 157, 254) por não apresentarem assinatura PNG no offset 0. A identificação por assinatura (file) revelou que eram imagens WebP animadas (contentor RIFF), renomeadas para .png.

Ficheiro	Tipo real
32-...09aa-fakepng.png	RIFF / WebP (animado, com alpha)
58-...08fea-fakepng.png	RIFF / WebP (animado, com alpha)
153-...5d6e-fakepng.png	RIFF / WebP (animado, com alpha)
157-...7d19-fakepng.png	RIFF / WebP (animado, com alpha)
254-...2b9b-fakepng.png	RIFF / WebP (animado, com alpha)

São um caso de ocultação por extensão trocada, mas sem payload escondido: o conteúdo é uma imagem legítima. O binwalk só devolveu falsos positivos (JBOOT), o que confirma que não há dados anexados. Parecem ser ruído deliberado (red herring) para dispersar a análise.

Para rastreabilidade individual (ISO/IEC 27037), calculámos os valores de hash SHA-256 dos cinco ficheiros no ambiente Kali Linux (sha256sum). Identificámo-los todos como contentores RIFF/WebP, distintos da extensão .png declarada:

```
32-350111...09aa : 7a55ba1a17c70f3c2166cca4dac0d5dd7c4614fec8ac89d67ffeb6cde8e6d97e
58-1107bdc...08fea : c6c888ef2f27f17447c82f5a65fb66400a319703a2e1526dea603fc9b07c0074
153-79c441...5d6e : 194e6089d615aec06ca844d5ea48177cee43eaf8d38d8af3544398c1cf86f06e
157-aef33a...7d19 : b63d8c76951107c20b381ffe59144dbd7e54f047abca95c0442a50d9610edd85
254-64bc38...2b9b : ca8087acfac99c46a2a7d31002f9d13aa665d815703abd333f31c3b946b1c6d
```

4.5. Síntese das técnicas de ocultação

A investigação identificou três técnicas distintas de ocultação na mesma imagem (extensão trocada com payload, polyglot por anexação e extensão trocada sem payload), cuja eficácia é avaliada em conjunto na secção 10.1.

Varrimento de completude: Para garantir que a análise das técnicas de ocultação foi exaustiva e não apenas por amostragem, varremos os 80 ficheiros da árvore \\imagens\\ por duas vias (o total de 81 registado no ingest inclui ainda uma imagem localizada fora desta árvore): (i) verificar a assinatura de cabeçalho (magic bytes) de cada ficheiro, para detetar extensões trocadas; e (ii) procurar a assinatura ZIP «50 4B 03 04» (PK) em qualquer posição de cada ficheiro, para detetar conteúdo OOXML anexado (polyglots), que a verificação de cabeçalho não mostra.

O varrimento confirmou a presença de exatamente dois ficheiros com conteúdo OOXML embutido, coincidentes com os artefactos já identificados:

```
inode 5132    -> PK no offset 0          (Artefacto 1, .xlsx puro)
inode 997389 -> PK no offset 0xBD72A      (Artefacto 2, polyglot)
```

Conclusão: Confirmámos ainda os cinco ficheiros «-fakepng» (assinatura RIFF/WebP), sendo os restantes 73 ficheiros imagens legítimas (PNG ou JPEG). Não identificámos qualquer payload adicional com assinatura de ficheiro reconhecível. Concluimos que os dois artefactos OOXML documentados constituem a totalidade do conteúdo exfiltrado sob a forma de imagem na fonte examinada. O offset de deteção do polyglot (0xBD72A) coincide com o determinado na extração da secção 4.3, o que constitui validação independente.

O alcance desta conclusão é limitado. Os dois métodos de varrimento que aplicámos procuram assinaturas de ficheiro: o primeiro no cabeçalho, o segundo em qualquer posição do ficheiro. Ambos detetam conteúdo anexado ou substituído que mantenha uma estrutura reconhecível. Nenhum deles deteta esteganografia por manipulação dos bits menos significativos, dados escondidos em blocos auxiliares do formato PNG, como os tEXt ou zTXt, ou informação cifrada sem cabeçalho identificável. A triagem por exiftool cobre a camada de metadados e a triagem por binwalk cobre ficheiros embebidos com assinatura conhecida, mas nenhuma das duas testa a camada dos pixéis. O que ficou demonstrado é que não existem ficheiros dissimulados nas imagens, e não que as imagens não contenham informação escondida por outros meios.

5. Registo de evidências (prints)

As figuras deste relatório documentam as operações que realizámos, associando cada passo à ferramenta e ao resultado correspondente.

Fig.	Fase	Evidência
1	Integridade	FTK Imager: Verify (MD5/SHA-1 Match)
2	Exame	Autopsy: Suspicious Items / Extension Mismatch
3	Exame	Vista hexadecimal: magic 50 4B 03 04
4	Preservação	PowerShell Get-FileHash: SHA-256 e MD5 do artefacto
5	Conteúdo	Aba «Users»: 20 contas com credenciais
6	Metadados	app.xml: gerado por Openpyxl 3.1.5
7	Metadados	core.xml: creator «openpyxl»; created = modified
8	Metadados	Autopsy (Data Artifacts): autoria openpyxl
9	Ocultação	Kali/Thunar: lote de 81 ficheiros exportados
10	Ocultação	Kali (exiftool): varrimento das 81 imagens
11	Ocultação	Kali (binwalk): falsos positivos (JBOOT/MySQL) num «-fakepng» vs. deteção real (ZIP) no polyglot
12	Ocultação	Kali (icat / sha256sum / xxd): SHA-256 do polyglot
13	Conteúdo	sheet1.xml do polyglot: orçamento com fórmulas SUM
14	Conteúdo	Payload extraído aberto no Excel

Fig.	Fase	Evidência
15	Sistema de ficheiros	Kali (fsstat): volume FAT32, rótulo ESD-USB
16	Ficheiros eliminados	Autopsy: pesquisa por atributos (2026-06-25)
17	Linha temporal	Kali (istat): marcas temporais da entrada 5132
18	Ficheiros eliminados	Autopsy: «Credential Stealer.bat», zero bytes
19	Ficheiros eliminados	Autopsy: File Metadata das instruções ofuscadas
20	Exfiltração	Kali (TSK + base64): log de exfiltração decodificado
21	Recuperação	Kali (foremost): carving recuperou os 2 arquivos ZIP; SHA-256 coincidentes
22	Interface	Autopsy (Keyword Search): «Secret123» em espaço não-alocado (Main.bat)
23	Ficheiros eliminados	Kali (fls / icat): extração dos 2 «.opdownload» (inodes 15/25)
24	Autoria	Kali (xmllint): custom.xml vazio do polyglot

6. Estado das diligências

Concluimos os passos que tínhamos planeado, o que sustenta a reconstrução do incidente apresentada na secção 7: **Ficheiros eliminados**: o processamento identificou 608 ficheiros eliminados na imagem, cuja triagem completa consta do ponto 7.8. Recuperámos e preservámos os artefactos relevantes

(scripts de designação sugestiva, reclassificados em 7.8; ficheiro de instruções ofuscado, 7.4–7.5; e interface de controlo de acesso, 7.7). Executámos o carving redundante por assinatura (foremost) sobre a imagem montada, que validou os artefactos OOXML por convergência de hashes (7.6).

Linha temporal: a marca temporal 2026-06-25 é comum aos timestamps do sistema de ficheiros e aos metadados internos dos dois artefactos OOXML, permitindo correlacionar a criação e a colocação dos ficheiros com o registo de exfiltração decodificado (7.5).

Métodos de recuperação: recuperámos os artefactos por duas vias metodologicamente independentes: pelo endereço de metadados, com o Autopsy e o icat, e pela assinatura de ficheiro, com o foremost. O recorte por offset com dd e a leitura de cadeias com strings serviram para extrair conteúdo de objetos já recuperados, e não para os recuperar.

7. Recuperação de ficheiros eliminados e automação de exfiltração

Retomando a frente aberta na secção 6, passámos à triagem dos 608 ficheiros eliminados que o Autopsy sinalizou. Seguimos o método de redundância do NIST SP 800-86 (cruzar o nó «Deleted Files» do Autopsy com a pesquisa por atributos), à procura de artefactos de exfiltração que não estivessem no espaço alocado: sobretudo scripts, notas ou instruções deixadas pelo agente.

7.1. Filtragem temporal por atributos

Antes de filtrar, caracterizámos a fonte. O fsstat identifica um volume FAT32 rotulado ESD-USB, precedido de 2048 sectores. Este dado condiciona tudo o que se segue: um volume FAT não possui \$MFT, \$LogFile nem \$UsnJrnl, pelo que a recuperação assenta nas entradas de directório e no espaço não alocado, e não nos metadados ricos que o NTFS disponibilizaria.

Para reduzir o ruído (por exemplo, ficheiros de aplicações legítimas com timestamps dispersos, como componentes de videojogos «BootUX.sqml» ou «SoulSacrificeDelta», que nos podiam induzir em erro), usámos o motor «File Search by Attributes» do Autopsy, restringindo a pesquisa à data crítica de 2026-06-25, com os campos temporais do filtro ativos sobre a fonte «Imagem AFD.E01». Um volume FAT32 regista apenas três marcas por entrada de directório (escrita,

acesso e criação), sendo a de acesso registada apenas ao dia. O filtro reduziu o conjunto à janela em que os payloads foram criados.

```
david@kali: ~  
  
(david@kali)-[~]  
$ sudo fsstat /mnt/ewf/ewf1 | head -14  
FILE SYSTEM INFORMATION  
-----  
File System Type: FAT32  
  
OEM Name: MSDOS5.0  
Volume ID: 0x8481cc7e  
Volume Label (Boot Sector): NO NAME  
Volume Label (Root Directory): ESD-USB  
File System Type Label: FAT32  
Next Free Sector (FS Info): 444224  
Free Sector Count (FS Info): 66664640  
  
Sectors before file system: 2048  
  
(david@kali)-[~]  
$
```

Figura 15. Kali (The Sleuth Kit): fsstat confirma FAT32, rótulo ESD-USB e 2048 sectores reservados antes do sistema de ficheiros.

File Search by Attributes

☐ Name:
*Note: Name match is case insensitive and matches any part of the file name (not including parent path). Regular expressions are not currently supported

☒ Date: 06/25/2026 ... to 06/25/2026 ...
*Empty fields mean "No Limit" *The date format is mm/dd/yyyy
Timezone: (GMT+0:00) Europe/Lisbon

☐ Size: equal to 0 Byte(s)

☐ MIME Type:
application/activemessage
application/andrew-inset
application/applefile
application/appxware
application/atom+xml

☐ Known Status:
☒ Unknown ☒ Known (NSRL or other) ☒ Notable

☐ Data Source:
Imagem AFD.E01

☐ MD5:
*Note: Multiple MIME types can be selected

☐ SHA-256:
*Note: Multiple data sources can be selected

☐ Deleted

Search Close

Figura 16. Autopsy: pesquisa por atributos restrita a 2026-06-25 sobre a imagem pericial.

```
david@kali: ~  
  
(david@kali)-[~]  
$ sudo istat /mnt/ewf/ewf1 5132 | head -11  
Directory Entry: 5132  
Allocated  
File Attributes: File, Archive  
Size: 7384  
Name: 474F60~1.PNG  
  
Directory Entry Times:  
Written: 2026-06-25 18:58:40 (BST)  
Accessed: 2026-06-25 00:00:00 (BST)  
Created: 2026-06-25 22:51:27 (BST)
```

Figura 17. Kali (The Sleuth Kit): istat da entrada de directório 5132; as três marcas temporais do FAT32, com o acesso registado apenas ao dia.

7.2. Confirmação do Artefacto 1 na linha temporal

A filtragem confirmou o ficheiro de credenciais disfarçado (474f60f4caba8dc26e7a56bacc39c18.png), com marca de escrita às 18:58:40 WEST. Esta marca e a data interna do metadado OOXML apurada na secção 3 (17:58:49Z) não são a mesma coisa: a primeira é atribuída pelo sistema de ficheiros da pen, a segunda foi gravada pelo openpyxl no momento em que gerou a folha. Correspondem a camadas distintas e a instantes distintos, ainda que ambos caiam no mesmo dia. O Autopsy manteve o alerta de «Extension Mismatch», confirmando a deteção da secção 2. Para fixar os valores sem intermediação de ferramenta gráfica, extraímos as marcas directamente da entrada de directório com istat: escrita a 18:58:40, criação a 22:51:27 e acesso registado apenas ao dia, como é próprio do FAT32.

7.3. Scripts de designação sugestiva (recolha de credenciais e dados)

A triagem revelou dois scripts de automação em lote (batch), com marca temporal de 2026-07-02, posterior à colocação dos artefactos OOXXML. Cada um deles ocupa três entradas no sistema de ficheiros, listadas abaixo com o respetivo endereço de metadados:

Ficheiro	Endereço	Estado	Dimensão	Data (criação)
Credential Stealer.bat	11	Eliminado	0 bytes	2026-07-02 20:06 WEST
Credential Stealer.bat.opdownload	15	Eliminado	166 bytes	2026-07-02 20:05 WEST
Credential Stealer.bat	18	Alocado	166 bytes	2026-07-02 20:06 WEST
Data Stealer.bat	21	Eliminado	0 bytes	2026-07-02 20:07 WEST
Data Stealer.bat.opdownload	25	Eliminado	181 bytes	2026-07-02 20:07 WEST
Data Stealer.bat	28	Alocado	181 bytes	2026-07-02 20:07 WEST

As três entradas de cada script explicam-se pelo comportamento do navegador. O Opera escreve o ficheiro com o sufixo .opdownload enquanto a transferência decorre, e renomeia-o quando esta termina; a entrada de dimensão nula é a reserva de nome que o processo deixa para trás. Extraímos os conteúdos com o icat e confirmámos, com o cmp, que o ficheiro .opdownload e o ficheiro .bat alocado são idênticos byte a byte. Apenas as entradas eliminadas de dimensão nula não têm conteúdo. Ao inspecionar o conteúdo em modo Hex/Text, encontrámos instruções de linha de comandos em texto limpo, com a estrutura «@echo off ... echo ... pause». O que ali está escrito não executa qualquer operação sobre ficheiros ou credenciais: limita-se a imprimir uma mensagem no ecrã e a aguardar. A designação dos ficheiros contrasta, portanto, com o que eles fazem, e retomamos o assunto no ponto 7.8.

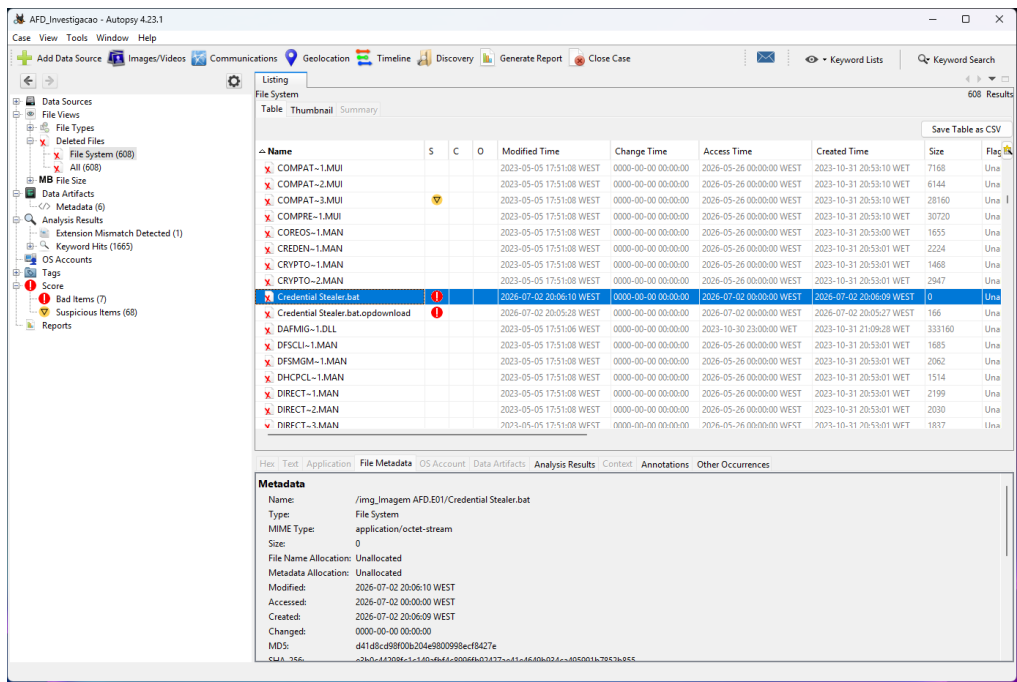


Figura 18. Autopsy: «Credential Stealer.bat» no painel Deleted Files. Zero bytes, alocação nula e MD5 do ficheiro vazio (d41d8cd9...). Logo abaixo, o «.opdownload» com 166 bytes — é aí que o conteúdo sobrevive (ponto 7.8)

7.4. Ficheiro de instruções ofuscado (Base64)

Numa primeira análise, vimos que o texto não estava legível de forma direta: estava ofuscado em Base64, com caracteres «=» que apontam para um cabeçalho ou separador no texto original.

Integridade: calculámos o hash de referência deste ficheiro (SHA-256: f3078fd59e8672738a51a2c7b4a58ba2bdb6133721c558d8e903c431e2ad0722) sobre o artefacto extraído, garantindo a sua rastreabilidade.

Name	Size	Flags	Modified Time	Change Time	Access Time	Created Time
412094d5270634c98fcaad08837.png-slick	25409	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
SoulSacrificedDefeat-2344455671.jpg-slick	809692	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
7a3a8a489295483b9f9c27c3638.png	9508	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
7a3a8a489295483b9f9c27c3638.png-slick	20600	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
9c7e119ed512a4c1994d4d0207c.png	12188	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
9c7e119ed512a4c1994d4d0207c.png-slick	24958	Allocated	2026-03-05 18:14:38 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:52:39 WEST
images	0	Unallocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 20:04:37 WEST
478094c6a8d626e7a50bacc39c18.png	7384	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:27 WEST
478094c6a8d626e7a50bacc39c18.png-slick	25384	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:27 WEST
35c744a5458a18a95050a0d6d7e.png	79370	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:43 WEST
35c744a5458a18a95050a0d6d7e.png-slick	25630	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:43 WEST
instructions to install imgs.tst-slick	1196	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:43 WEST
ad6	31172	Allocated	2026-06-25 18:54:02 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:43 WEST
[current folder]	32768	Allocated	2026-06-25 18:56:18 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:27 WEST
afineage	32768	Allocated	2026-06-25 18:56:18 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:27 WEST
[current folder]	32768	Allocated	2026-06-25 18:56:18 WEST	0000-00-00 00:00:00	2026-06-25 00:00:00 WEST	2026-06-25 22:51:27 WEST

Figura 19. Autopsy: File Metadata do ficheiro de instruções (MD5/SHA-256: Not calculated: ficheiro eliminado).

7.5. Decodificação do ficheiro de instruções e registo de exfiltração

Extraímos o ficheiro diretamente da imagem pericial, com o The Sleuth Kit, e decodificámo-lo sem o guardar em disco pelo caminho. Assim não há cópias intermédias que alguém possa pôr em causa. Confirmámos primeiro, com fsstat, que o volume é FAT32, rotulado ESD-USB e precedido de 2048 sectores. O ficheiro exposto pelo ewfmount começa no sistema de ficheiros, pelo que a extração pelo endereço de metadados (5132 para o Artefacto 1; 1881120 para o ficheiro de instruções) dispensa indicar um deslocamento explícito:

```
$ sudo ewfmount ".../Imagem AFD.E01" /mnt/ewf
$ sudo icat /mnt/ewf/ewf1 1881120 | sha256sum
$ sudo icat /mnt/ewf/ewf1 1881120 | base64 -d
```

A decodificação Base64 (1596 bytes de entrada — 1196 bytes de saída) revelou não um conjunto de instruções de instalação, como o nome do ficheiro sugeria, mas o registo de execução (log) da própria rotina de exfiltração. É um relato cronológico datado de 2026-06-25, a mesma data em que os artefactos OOXML foram criados:

```
david@kali: ~/Desktop/export
f3078fd59e8672738a51a2c7b4a58ba2bdb6133721c558d8e903c431e2ad0722 -
=====
[2026-06-25 18:15:00] INIT: Sincronizador Automático (PID: 4892) iniciado.
[2026-06-25 18:15:02] CONFIG: Carregando parâmetros de execução silenciosa... OK.
[2026-06-25 18:15:05] SCAN: A analisar pasta de origem: \Administracao\Financeiro\
[2026-06-25 18:15:07] SCAN: Encontrados 2 ficheiros relevantes em \Administracao\Financeiro\
[2026-06-25 18:15:15] PROCESS: A copiar dados para memória temporária (cache)...
[2026-06-25 18:15:22] PROCESS: Compressão e ofuscação de pacote de dados iniciada.
[2026-06-25 18:15:27] EXPORT: A transferir pacote principal para o destino: \arquivos da pen\imagens\Blasphemous\
[2026-06-25 18:15:32] EXPORT: Sucesso. Pacote injetado na diretoria de destino.
[2026-06-25 18:15:35] EXPORT: A transferir chaves de registo para destino secundário: \arquivos da pen\logs_sistema\
[2026-06-25 18:15:40] CLEANUP: A limpar rasto de ficheiros temporários locais...
[2026-06-25 18:15:42] CLEANUP: Eliminação de registos do Windows concluída.
[2026-06-25 18:15:45] EXIT: Exfiltração concluída com sucesso. Rotina terminada.
=====
(david@kali)-[~/Desktop/export]
$
```

Figura 20. Kali (The Sleuth Kit + base64): o ficheiro extraído pelo endereço de metadados 1881120, com o respetivo SHA-256, e o registo de exfiltração que a decodificação revela.

Ao analisar as entradas do log, reconstruímos a operação e correlacionámo-la com os artefactos já identificados:

Fase (timestamp WEST)	Entrada do log	Leitura forense
18:15:00 INIT	Sincronizador Automático (PID 4892) iniciado	Processo com denominação inócua (disfarce de tarefa legítima); execução silenciosa
18:15:05 SCAN	Análise de \Administracao\Financeiro\ : 2 ficheiros	Alvo dirigido; corresponde aos dois artefactos OOXML (credenciais + orçamento)
18:15:22 PROCESS	Compressão e ofuscação de pacote de dados	Técnica de ocultação documentada na secção 4 (polyglot / extensão trocada)
18:15:27 EXPORT	Pacote principal → \imagens\ Blasphemous\	Exfiltração dissimulada entre imagens de videogame (mesmo padrão dos WebP «red herring»)
18:15:35 EXPORT	Chaves de registo → \logs_sistema\	Exfiltração secundária de configuração do sistema
18:15:42 CLEANUP	Eliminação de registos do Windows concluída	Anti-forense deliberado (limpeza de Event Logs); evidência intencionalidade
18:15:45 EXIT	Exfiltração concluída com sucesso	Rotina terminada às 18:15:45, antes de qualquer marca temporal do Artefacto 1

Nota de localização: o log declara \imagens\Blasphemous\ como destino, mas o Artefacto 1 encontra-se em \imagens\ac6\ — pasta irmã, não subpasta. A divergência é coerente com a dispersão por pastas de camuflagem (secção 10.1) e não indica execuções adicionais da rotina.

Significado probatório: este é o elemento central da investigação. Ao contrário dos ficheiros OOXML (que são o produto da exfiltração), o log mostra a intenção, o método e a sequência do ato, incluindo uma fase explícita de destruição de vestígios (anti-forense). O nome enganador do ficheiro («instructions to install imgs.txt» [sic], com a grafia errada no original) e a codificação Base64 do conteúdo, a que se soma a eliminação posterior do próprio ficheiro, reforçam a ideia de que a operação foi deliberada. O log foi escrito pelo próprio autor da rotina, e isso obriga a alguma cautela na leitura. Prova que houve intenção e mostra o método que estava planeado. Já as ações que descreve não se podem tomar como verificadas só porque estão lá escritas: valem quando outra coisa as confirma. A técnica de ocultação e a data de criação dos ficheiros confirmam-nas. A pasta \Administracao\Financeiro\ não, porque não existe na imagem que analisámos.

Rastreabilidade da descodificação: o ficheiro ofuscado continua na imagem pericial, com o SHA-256 f3078fd59e8672738a51a2c7b4a58ba2bdb6133721c558d8e903c431e2ad0722. Descodificámo-lo com o base64 -d, o que deu 1196 bytes e o SHA-256 f8097bffd0d11bef6af9ee226f551f86b18f7d94780ede63a08f96ad567c6fdd. Registámos os dois valores porque a descodificação transforma o ficheiro, e sem eles não haveria forma de mostrar que o texto que apresentamos é o que estava lá. Corremos o icat e o base64 -d diretamente sobre a imagem, sem guardar cópias pelo caminho, de modo a que qualquer pessoa possa repetir os mesmos dois comandos e chegar ao mesmo hash (ISO/IEC 27037).

7.6. Validação redundante por carving de assinatura (foremost)

Complementámos a recuperação por endereço de metadados (icat / Autopsy) com carving por assinatura sobre a imagem pericial. Montámos a imagem com ewfmount (juntando os quatro segmentos .E01-.E04 num único volume lógico) e corremos o foremost sobre o dispositivo resultante, que recuperou 285 ficheiros por deteção de números mágicos, sem depender das entradas de directório do sistema de ficheiros.

O relatório de auditoria do foremost (audit.txt) regista apenas duas ocorrências do tipo zip em toda a imagem. Não existe, portanto, um terceiro arquivo OOXML por identificar: os dois artefactos documentados esgotam o conteúdo desse tipo recuperável por assinatura.

Dos ficheiros recuperados, dois arquivos OOXML apresentaram valores SHA-256 idênticos aos Artefactos 1 e 2, previamente extraídos por endereço de metadados:

```
david@kali: ~  
$ grep -E "FILES EXTRACTED|zip:=" carving_full/audit.txt  
285 FILES EXTRACTED  
zip:= 2  
$ sha256sum 00026112.zip 00128043.zip  
780eab3894ac1ce478765a0fab50381abc47e2c1e2363fe2ded5a28faf055654 00026112.zip  
885d07cab942e94d2f96f35af3e2e7f5d7966b6412a7c80c7f028340ae2c4411 00128043.zip  
$ file 00026112.zip 00128043.zip  
00026112.zip: Microsoft Excel 2007+  
00128043.zip: Microsoft Excel 2007+  
  
(david@kali) ~  
$
```

Figura 21. Kali (foreground): carving por assinatura recuperou os dois arquivos ZIP (00026112.zip e 00128043.zip), com SHA-256 coincidentes com os Artefactos 1 e 2 extraídos por endereço de metadados.

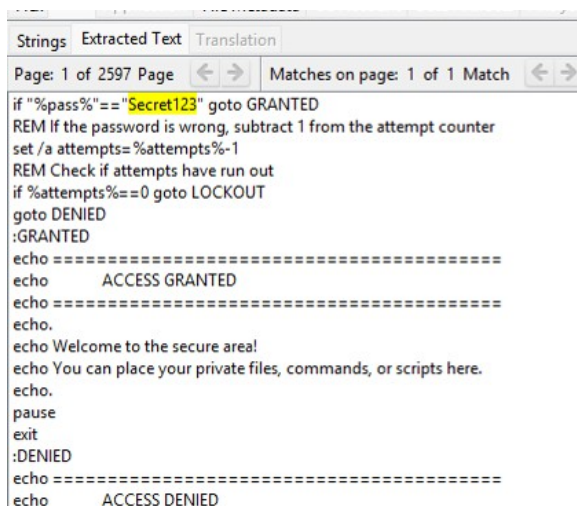
Ficheiro recuperado (foremost)	Correspondência	SHA-256 (coincidente)
00026112.zip	Artefacto 1: credenciais (icat/Autopsy)	780eab38...f055654
00128043.zip	Artefacto 2: payload extraído do polyglot (dd/Autopsy)	885d07ca...340ae2c4411

Convergência: os valores SHA-256 obtidos por foremost coincidem com os da recuperação por metadados (icat/Autopsy), ou seja, dois métodos independentes devolvem o mesmo conteúdo. O utilitário file identificou ambos os arquivos como «Microsoft Excel 2007+», sinal de que a estrutura OOXML se manteve completa.

7.7. Interface de controlo de acesso com credencial embutida

A pesquisa por cadeias de texto (strings) sobre a imagem montada revelou, no offset 335 544 000, um script batch (.bat) autodenominado «Secure Interface». Ao contrário dos artefactos anteriores, é o código de uma interface de autenticação que anuncia uma área de armazenamento de ficheiros e comandos, sem a implementar. Extraímos o script com dd e guardámo-lo separadamente para análise.

A rotina implementa um ecrã de autenticação («AUTHORIZED PERSONNEL ONLY») com contador de três tentativas e bloqueio (LOCKOUT). e compara a palavra-passe diretamente, com a credencial escrita em texto claro no próprio código:



```
Strings  Extracted Text  Translation
Page: 1 of 2597 Page  Matches on page: 1 of 1 Match
if "%pass%"=="Secret123" goto GRANTED
REM If the password is wrong, subtract 1 from the attempt counter
set /a attempts=%attempts%-1
REM Check if attempts have run out
if %attempts%==0 goto LOCKOUT
goto DENIED
:GRANTED
echo =====
echo     ACCESS GRANTED
echo =====
echo.
echo Welcome to the secure area!
echo You can place your private files, commands, or scripts here.
echo.
pause
exit
:DENIED
echo =====
echo     ACCESS DENIED
```

Figura 22. Autopsy (Keyword Search): «Secret123» localizada em espaço não-allocado, confirmando a credencial embutida no script «Main.bat».

O que a interface faz: a palavra-passe «Secret123» está escrita em texto claro (hardcoded) na linha que a compara, o que anula a proteção: quem leia o ficheiro contorna o mecanismo. A mensagem que aparece depois da autenticação («You can place your private files, commands, or scripts here») liga esta interface ao alojamento dos scripts de designação sugestiva vistos em 7.3 (Credential Stealer.bat, Data Stealer.bat), reclassificados em 7.8 como elementos de dissimulação; pode ser a fachada de acesso a esses ficheiros.

Integridade: SHA-256 do script extraído (secure_interface.bat, 1622 bytes):
7871b57b9a4bfcc91a47538d1e6eb27a0ffc9c5ab790c78e1ef7d55e637cce6b.

Confirmação no Autopsy: depois de reindexar a fonte com o Keyword Search (Solr), a pesquisa por «Secret123» encontrou o mesmo código num bloco de espaço não-allocado (Unalloc_1006_227442688_1301184512, em /\$Unalloc/). O bloco não tem entrada de directório associada (datas a «0000-00-00» e estado «Unallocated»), o que confirma eliminação sem metadados de sistema recuperáveis. O hash do bloco (42A1A8C308F538CBC2EEA32F583BBDECAF3F73732DEC2825CAAED019A84B50AA, valor em maiúsculas tal como o Autopsy o apresenta) difere do hash do script isolado, porque o bloco arrasta dados residuais à volta; o que confirma o achado é o código ser idêntico, não o contentor. Os fragmentos de texto no mesmo bloco mostram de onde vinha o artefacto: o script estava numa pen com rótulo «ESD-USB» (E:\), com o nome real «Main.bat», e apontava para o ícone SHELL32.dll do sistema, para se fazer passar por ficheiro legítimo. Estar numa unidade removível é coerente com o cenário de exfiltração para dispositivo externo. Como o «Main.bat» só existia em espaço não-allocado, o carving por cadeias (strings/dd) foi a via adequada para o recuperar, constituindo um terceiro método independente de recolha, a somar à recuperação por metadados e por assinatura (NIST SP 800-86).

7.8. Triagem completa dos ficheiros eliminados e reclassificação dos scripts

Depois de recuperar os artefactos-chave, fizemos uma triagem dos 608 ficheiros no estado eliminado que o Autopsy lista no painel Deleted Files, exportando a lista com os respetivos metadados para garantir rastreabilidade. Cruzámos cada entrada com os factos já apurados (caminho, extensão e marca temporal) e distribuímos-las por quatro categorias: 7 de relevância elevada, 17 de relevância média, 487 ficheiros de sistema e 97 restantes não alocados. Os ficheiros de sistema, cerca de 80% do total, são componentes normais de um volume de sistema sem ligação ao caso, pelo que os registámos mas não os analisámos individualmente.

Na categoria de relevância elevada destacam-se os quatro registos com a etiqueta Scripts_Exfiltracao no Autopsy, datados de 2 de julho de 2026: os ficheiros «Credential Stealer.bat» e «Data Stealer.bat» e os respetivos ficheiros residuais «.opdownload» do navegador Opera. Como se verá, a estes quatro registos eliminados correspondem ainda duas entradas alocadas com o mesmo nome.

Ficheiros .bat: O painel Deleted Files do Autopsy lista, para cada script, uma entrada de dimensão nula, cujo SHA-256 é o do conteúdo vazio (e3b0c442...b855). Se a análise se ficasse por aqui, o conteúdo dos scripts teria de ser dado como irrecuperável. A enumeração das entradas do sistema de ficheiros com o fls mostra, porém, que existe também uma entrada alocada para cada um deles, que o painel de ficheiros eliminados naturalmente não apresenta. O «Credential Stealer.bat» ocupa o endereço de metadados 18 e tem 166 bytes, com o

SHA-256 5267bbeab810dd77729693685ebb6a5cd0cff12f852764d8c8e6677b8af7b228. O «Data Stealer.bat» ocupa o endereço 28 e tem 181 bytes, com o SHA-256 f02caeb06d67701006c97e137ab8f62b8ff1ce155894a2675c6dd8bdabb3e01. Extraímos ambos com o icat e comparámo-los, com o cmp, aos respetivos ficheiros .opdownload: são idênticos byte a byte. As entradas de dimensão nula não são, assim, versões truncadas dos scripts, mas resíduos do processo de descarregamento. O conteúdo operacional dos dois ficheiros está integralmente disponível.

Ficheiros .opdownload: Recuperámos igualmente os dois ficheiros residuais de descarregamento («Credential Stealer.bat.opdownload», 166 bytes, e «Data Stealer.bat.opdownload», 181 bytes), e extraímos o texto com a funcionalidade Extracted Text do Autopsy. Sendo idênticos aos .bat alocados, o conteúdo apurado por esta via é o mesmo, o que constitui confirmação por dupla origem:

```
Credential Stealer.bat.opdownload:
@echo off
echo =====
echo.
echo Alvo n/encontrado. Nenhum Log criado.
echo.
echo =====
pause
Data Stealer.bat.opdownload:
@echo off
echo =====
echo.
echo Alvo e Credenciais n/encontradar. Nenhum Log criado.
echo.
echo =====
pause
```

Apreciação: O conteúdo integral de ambos é inócuo. Não há instruções de cópia, de movimentação, de ligação de rede ou de acesso a credenciais: apenas mensagens a indicar que não há alvo e que não foi criado registo, seguidas de uma pausa. Uma vez que dispomos do conteúdo completo dos scripts, e não apenas de um fragmento, esta apreciação não depende do que possa faltar: nada falta. Concluimos que estes ficheiros não são scripts de exfiltração a funcionar, mas elementos de dissimulação (stubs), cujo nome sugestivo contrasta com a função inofensiva, o mesmo padrão dos cinco ficheiros «-fakepng» (secção 4.4) e do script «Secure Interface» (secção 7.7).

Não existe, portanto, prova de que a exfiltração de dados tenha sido efetuada através destes ficheiros. A exfiltração efetivamente documentada consta de artefacto distinto (o ficheiro «intructions to install imgs.txt» e o respetivo registo de execução da rotina «Sincronizador Automático», secções 7.4 e 7.5). Os dois achados são autónomos e não devem ser confundidos.

Identificámos ainda, na categoria de relevância elevada, dois ficheiros .vbs de conteúdo idêntico (etwproviderinstall.vbs e a respetiva designação curta 8.3, mesmo valor SHA-256 1ab7ae96..., datados de 2023), correspondentes a componente legítimo do sistema operativo (instalação de fornecedor ETW) sem nexos com a investigação, e uma entrada de diretório eliminada de designação truncada («_magens», 0 bytes, criada a 25 de junho de 2026), cuja proximidade temporal com a geração dos payloads e cuja designação sugerem resíduo do diretório \imagens\ utilizado como destino de exfiltração.

Para reforçar a triagem, e seguindo o princípio de redundância do NIST SP 800-86, extraímos os dois ficheiros residuais «.opdownload» por uma via diferente da do Autopsy. Sobre a imagem montada (ewfmount), localizámos os endereços de metadados com o utilitário fls (inodes 15 e 25, ambos não alocados) e extraímos o conteúdo com o icat.

```
(david@kali)-[~]
$ sudo icat /mnt/ewf/ewf1 18 > cred.bat
sudo icat /mnt/ewf/ewf1 28 > data.bat
cmp cred.bat cred.opdownload; echo "rc=$?"
cmp data.bat data.opdownload; echo "rc=$?"
sudo icat /mnt/ewf/ewf1 15 | sha256sum
sudo icat /mnt/ewf/ewf1 25 | sha256sum
rc=0
rc=0
5267bbeab810dd77729693685ebb6a5cd0cfff12f852764d8c8e6677b8af7b228 -
f02cae0b6d67701006c97e137ab8f62b8fff1ce155894a2675c6dd8bdabb3e01 -
(david@kali)-[~]
$
```

Figura 23. Kali (fls / icat): extração dos dois «opdownload» (inodes 15 e 25) por via independente do Autopsy; SHA-256 coincidentes confirmam a recuperação.

Validação: Os valores SHA-256 obtidos por icat coincidem com os que o Autopsy registou para os mesmos ficheiros, confirmando que a extração é fiel. Chegar ao mesmo resultado por duas vias independentes reforça a fiabilidade da recuperação.

8. Consolidação e hipótese de trabalho

Juntámos os elementos recolhidos, e os indícios apontam, com grau de confiança elevado, para um cenário de ameaça interna (insider threat) com exfiltração dirigida de dados sensíveis:

Elemento	Evidência de suporte
Acesso privilegiado a dados financeiros	Log de exfiltração dirigido a \Administracao\Financeiro\; artefacto de credenciais com contas «adm»/«adm.backup»
Exfiltração efetiva	Dois artefactos OOXML (credenciais + orçamento) ocultos por extensão trocada e polyglot
Método deliberado e automatizado	Metadados openpyxl (criação=modificação); rotina «Sincronizador Automático» com fases INIT, SCAN, EXPORT e CLEANUP
Anti-forense	Fase CLEANUP no log (eliminação de Event Logs); ficheiros marcados como eliminados
Autoria	Não estabelecida. A conta «osilva» aparece como única «Disabled» na tabela exfiltrada, mas esse dado provém do artefacto e não de evidência de sistema

Classificação do incidente: com base nos elementos consolidados, classificámos o incidente segundo a Taxonomia Comum da Rede Nacional de CSIRT (RNCsIRT, 2023), o referencial adotado em Portugal pelo CERT.PT para a classificação de incidentes de cibersegurança. A taxonomia assenta em dois vetores, o «Tipo de Incidente» e o «Tipo de Evento», e prevê que, quando são aplicáveis várias classificações, a classificação primária corresponda ao objetivo do agente e a secundária ao meio empregue para o concretizar.

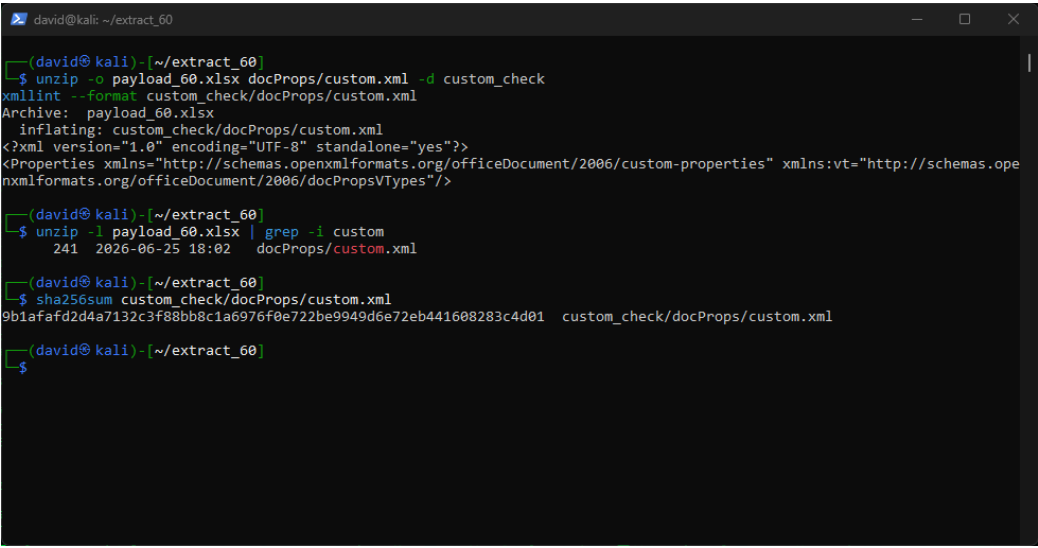
Classificação primária: classe «Segurança da Informação», tipo «acesso ou exfiltração não autorizada de informação». É o objetivo final que os indícios apontam para o incidente, a recolha e a extração dirigida de dados da área \\Administracao\\Financeiro\\, materializada nos dois artefactos OOXML (credenciais e orçamento) e descrita no registo de execução da rotina «Sincronizador Automático» (secção 7.5).

Classificação secundária: classe «Intrusões», relativa ao meio de acesso, correspondente à interface de autenticação «Main.bat» com credencial embutida em texto claro (secção 7.7), que descreve o mecanismo de acesso à área onde os ficheiros eram colocados.

A fase CLEANUP declarada no registo (eliminação dos registos de eventos do Windows) constitui uma ação anti-forense associada ao incidente e não uma classe autónoma na taxonomia. As técnicas de ocultação identificadas na secção 4 (extensão trocada, polyglot) são o mecanismo de transporte e dissimulação, e não um tipo de incidente distinto. Mantém-se a cautela probatória exposta ao longo do relatório: a classificação assenta nos artefactos recuperados e no registo descodificado, e não numa atribuição de autoria, que permanece circunstancial (secção 10.3).

A análise do custom.xml do polyglot afasta a hipótese de autoria humana neste artefacto. A fonte examinada é lógica e não contém hives do registo, entradas .lnk nem registos USBSTOR — não há, por isso, artefacto que ligue uma conta concreta à execução da rotina.

Analisámos o ficheiro docProps/custom.xml do payload polyglot (payload_60.xlsx) em Kali Linux, descompactando o arquivo OOXML e formatando o XML com xmllint. O ficheiro existe na estrutura interna do documento (241 bytes), mas o elemento raiz <Properties> está vazio, sem qualquer propriedade de autoria, empresa ou gestor: aparece como uma marca auto-fechada, sem elementos-filho. Este resultado é coerente com o comportamento do openpyxl, que cria a estrutura de propriedades personalizadas por omissão mas não lhe atribui conteúdo. Esta ausência total de propriedades, tal como já tínhamos visto no Artefacto 1 (secção 3), afasta a hipótese de intervenção manual e aponta para uma geração totalmente automática. Para rastreabilidade, registámos o hash do próprio custom.xml, extraído do payload: SHA-256 9b1afafd2d4a7132c3f88bb8c1a6976f0e722be9949d6e72eb441608283c4d01. Não se confunde com o hash do payload que o contém (885d07ca...), nem com o do ficheiro polyglot (44bf6435...), ambos registados na secção 4.3. Com isto, fechamos a linha relativa à autoria do polyglot.



```
david@kali: ~/extract_60
(david@kali) - [~/extract_60]
$ unzip -o payload_60.xlsx docProps/custom.xml
xmllint --format custom_check/docProps/custom.xml
Archive:  payload_60.xlsx
  inflating: custom_check/docProps/custom.xml
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<Properties xmlns="http://schemas.openxmlformats.org/officeDocument/2006/custom-properties" xmlns:vt="http://schemas.openxmlformats.org/officeDocument/2006/docPropsVTypes"/>

(david@kali) - [~/extract_60]
$ unzip -l payload_60.xlsx | grep -i custom
      241  2026-06-25  18:02  docProps/custom.xml

(david@kali) - [~/extract_60]
$ sha256sum custom_check/docProps/custom.xml
9b1afafd2d4a7132c3f88bb8c1a6976f0e722be9949d6e72eb441608283c4d01  custom_check/docProps/custom.xml

(david@kali) - [~/extract_60]
$
```

Figura 24. Kali (xmllint / unzip / sha256sum): custom.xml do polyglot com elemento <Properties/> vazio; ausência de autoria confirmada.

Reverificámos a integridade da imagem de forma independente em Kali (ewfverify: MD5/SHA-1 coincidentes), o que garante que todas as conclusões assentam numa cópia fiel do original. As pesquisas por indicadores de exfiltração em rede (serviços de partilha, curl, wget, correio externo) não devolveram resultados, o que aponta para exfiltração exclusivamente por suporte removível (ESD-USB) e não por rede.

Fonte do estado da conta: o estado da conta «osilva» (Olivia Silva, Operations Manager, WKS-426) como única «Disabled» vem da tabela de credenciais exfiltrada (Artefacto 1), e não de uma extração de contas do sistema operativo: a análise de OS Accounts no Autopsy não devolveu resultados, o que é coerente com a natureza lógica da fonte (dispositivo removível, sem hives do registo do Windows). Das 20 contas listadas, só «osilva» aparece como «Disabled»; as restantes surgem como «Active». O artefacto traz ainda um aviso interno («FAKE / SYNTHETIC DATA: NOT REAL CREDENTIALS»): as credenciais são sintéticas, geradas para o exercício, e o valor da prova está no método de ocultação e exfiltração, não na autenticidade dos dados.

9. Conclusão

Investigámos a imagem pericial «Imagem AFD.E01-E04», verificada quanto à integridade em dois ambientes independentes (FTK Imager e ewfverify), e identificámos e documentámos um conjunto coerente de artefactos indicativos de exfiltração deliberada de dados.

Confirmámos cinco vetores: (1) um ficheiro de credenciais do domínio trhplus-demo.local, dissimulado como imagem PNG; (2) um ficheiro OOXML financeiro embebido num polyglot JPEG; (3) scripts com designação sugestiva de recolha de credenciais e dados, cuja análise revelou conteúdo não-operacional (elementos de dissimulação, secção 7.8); (4) um registo de execução da rotina de exfiltração «Sincronizador Automático», ofuscado em Base64, que documenta a varredura dirigida de \Administracao\Financeiro\, a ofuscação dos dados, a transferência para pastas de camuflagem

e a eliminação dos registos de eventos do Windows (ação anti-forense); e (5) uma interface de controlo de acesso (Main.bat) com credencial embutida em texto claro, residente em suporte removível.

Recuperámos e validámos os artefactos-chave por vias independentes, com registo de hashes SHA-256 em cada extração, segundo o NIST SP 800-86 (NIST, 2006) e a ISO/IEC 27037 (ISO/IEC, 2012).

A convergência dos elementos (acesso dirigido a dados financeiros, método automatizado, destruição de vestígios e uso de suporte removível) sustenta, com grau de confiança elevado, a hipótese de ameaça interna centrada na conta osilva (Operations Manager, WKS-426), única em estado Disabled. A atribuição individual permanece circunstancial, pelas razões expostas em 10.3. Segundo a taxonomia da Rede Nacional de CSIRT, o incidente classifica-se, a título primário, como um incidente de «Segurança da Informação» (acesso ou exfiltração não autorizada de informação), tendo as «Intrusões» como classificação secundária relativa ao meio de acesso (secção 8).

O relatório reflete os factos apurados até à data da sua emissão.

10. Avaliação crítica

10.1. Eficácia das técnicas de ocultação

A ocultação de informação é uma das técnicas que os grupos usam ao construir os cenários de ataque (Rosa, 2025a). No cenário que analisámos encontrámos cinco, com graus de eficácia diferentes.

Três correspondem a categorias da taxonomia apresentada na cadeira (Rosa, 2025a): a codificação (*Encoding*), aplicada ao conteúdo do ficheiro de instruções; a eliminação (*Delete*), aplicada aos ficheiros que o Autopsy listou como apagados; e a alteração de registos (*Log Alteration*), declarada na fase CLEANUP da rotina descodificada. As outras duas são formas de dissimulação de conteúdo que a taxonomia não nomeia: a troca de extensão e a anexação de um payload a um portador legítimo (polyglot). Esta última aproxima-se da esteganografia, porque esconde dados dentro de um ficheiro que continua a abrir normalmente. Mas não é o mesmo: a esteganografia esconde a própria existência da mensagem, enquanto aqui o payload está apenas anexado a seguir ao ficheiro portador, e por isso aparece num varrimento de offsets.

Nenhuma das técnicas era robusta quando vista isoladamente. A troca de extensão cai com uma verificação de assinatura. A codificação em Base64 não é cifra: não protege o conteúdo, só o torna ilegível a olho nu. E apagar ficheiros num volume FAT não elimina os dados, remove a referência, que é precisamente do que vive a recuperação de ficheiros eliminados. Os cinco ficheiros «-fakepng» demonstram a sua fragilidade: consumiram tempo de análise, mas não escondiam nada.

O que mais expôs a operação não foi a fragilidade de cada técnica isolada, mas um erro de quem a executou: a rotina deixou na própria fonte o registo da sua execução, ainda que ofuscado. A alteração de registos é, na taxonomia, uma técnica anti-forense. Aqui, ao ficar declarada por escrito, produziu o efeito contrário ao pretendido. Depois de recuperado e descodificado, esse ficheiro tornou-se a nossa peça central (secção 7.5) e transformou a fase CLEANUP em prova de que a operação foi intencional.

Nenhuma das técnicas resistiu à conjugação de três coisas: verificar assinaturas, varrer offsets e recuperar ficheiros eliminados. Daqui retiramos que o que compromete a ocultação não é a sofisticação de cada técnica, mas o rasto que o próprio ato de ocultar deixa.

10.2. Dificuldades encontradas durante a investigação

Relativamente as dificuldades encontradas, o carving por assinatura obrigou a um passo que não tínhamos previsto: a versão do foremost que usámos não lê diretamente o formato EWF, por isso tivemos de montar a imagem com ewfmount e correr a ferramenta sobre o dispositivo exposto (secção 7.6). É um caso concreto da falta de padronização entre ferramentas forenses, apontada como um dos desafios da análise forense digital (Rosa, 2025b).

A pesquisa por palavras-chave obrigou-nos a reprocessar a fonte no Autopsy. O módulo Keyword Search (Solr) não tinha ficado ativo na ingestão inicial, e indexar uma imagem de 32 GB por inteiro demora; só depois desse reprocessamento é que conseguimos correr a pesquisa por palavras-chave sobre a imagem.

A extração do payload do polyglot também não foi automática. O binwalk assinalou a assinatura ZIP embebida, mas separá-la exigiu determinar o offset exato (0xBD72A) e recortar o conteúdo com dd. A ferramenta encontrou o indício; correlacioná-lo com o resto e decidir o que fazer com ele foi trabalho nosso.

A triagem dos 608 ficheiros eliminados e dos cinco «-fakepng» ocupou boa parte do tempo de análise. Os «-fakepng» revelaram-se apenas ruído, sem payload: eram pistas falsas (*red herrings*), colocadas para desviar a atenção de quem investiga. Mas só verificando a assinatura de cada um é que os pudemos excluir com segurança, porque uma pista falsa só se distingue de uma verdadeira depois de examinada.

10.3. Limitações da análise

A fonte examinada é um volume FAT32 (confirmado por fsstat; o Autopsy expõe as tabelas de alocação \$FAT1 e \$FAT2), com o rótulo ESD-USB, correspondente a um dispositivo de armazenamento removível. Não contém sistema operativo nem os respetivos artefactos: sem \Windows\ ou \Users\, sem hives de registo, sem \$MFT, \$LogFile ou \$UsnJrnl, sem Prefetch e sem ficheiros de atalho .lnk. A análise de OS Accounts no Autopsy não devolveu resultados, coerentes com a natureza do volume. Ficam assim indisponíveis as fontes que sustentam boa parte da análise forense de sistemas Windows, como as chaves de registo, os registos de eventos, os ficheiros de atalho ou os artefactos de execução de programas (Haddad, 2021).

A principal limitação é esta: a atribuição individual de autoria não pode ser estabelecida a partir dos elementos contidos na imagem. Não há documentos com extensão Office legítima: todo o conteúdo OOXML está disfarçado de imagem e foi gerado programaticamente (openpyxl), sem metadados de autor. Os metadados dos ficheiros Office, como o autor ou a última gravação, são uma das vias habituais para identificar quem produziu um documento (Rosa, 2025b), e neste caso não existem. A associação à conta «osilva» (Operations Manager, WKS-426) assenta em evidência circunstancial: o conteúdo do Artefacto 1 e o estado «Disabled» da conta, único entre as vinte listadas. A leitura desse estado como indicio de cessação de funções é uma hipótese nossa, que a fonte não confirma. A correlação direta dispositivo—máquina—conta exigiria a análise da estação de origem WKS-426, fora do âmbito do material examinado.

A validação temporal assentou na convergência entre os timestamps do sistema de ficheiros, os metadados internos dos artefactos e o registo de exfiltração decodificado, todas fontes internas à própria imagem. O *time stamping*, ou manipulação das marcas temporais, é uma das técnicas de ocultação previstas na taxonomia da cadeira (Rosa, 2025a). Uma manipulação coordenada de datas não pode ser excluída em absoluto, embora nada na análise a sugira.

O conteúdo dos dados é sintético por natureza do exercício, como o próprio Artefacto 1 declara. O valor da análise reside na demonstração do método de ocultação e exfiltração, não na autenticidade da informação (secção 8).

11. Reflexão

Investigar um cenário construído por outro grupo obrigou-nos a alternar entre dois modos de pensar. Para reconstruir o incidente tivemos de imaginar como o grupo atacante raciocinou: onde esconderia um ficheiro, que extensão usaria para o disfarçar, que passos daria para apagar rastros. É esta alternância entre o ponto de vista de quem ataca e o de quem investiga que a metodologia da cadeira designa por *dual-role* (Rosa, 2025a), e foi ela que mais contribuiu para percebermos as decisões do cenário. É também o que distingue esta metodologia de um exercício de investigação isolado, e ajudou-nos a saber o que procurar quando recebemos o cenário de outro grupo.

Só depois de compreendermos a lógica do atacante é que algumas das nossas escolhas de análise fizeram sentido. A extensão .png num ficheiro que era, na verdade, uma folha de cálculo, ou o cabeçalho JPEG colocado à frente de um arquivo OOXML no polyglot, são técnicas que só se antecipam se pensarmos primeiro como quem as concebeu. Por isso, a verificação de assinaturas e a análise de offsets deixaram de ser passos mecânicos para se tornarem respostas a técnicas concretas que esperávamos encontrar.

O volume de dados notou-se na triagem dos 608 ficheiros eliminados, que nos obrigou a filtrar antes de analisar. A correlação entre fontes fragmentadas permitiu-nos ligar o registo de exfiltração aos artefactos e aos timestamps.

Quanto ao desenho do cenário, a leitura que fazemos é a de um trabalho pensado para pôr à prova a nossa capacidade de distinguir o essencial do ruído. O grupo atacante não se limitou a esconder os artefactos verdadeiros; espalhou também distrações. Os cinco ficheiros «-fakepng», os scripts de nome sugestivo que afinal estavam vazios e a interface «Secure Interface» com uma palavra-passe à vista funcionam como *red herrings*, elementos concebidos para consumir tempo de análise. Aprender a excluí-los com base em evidência, e não por intuição, foi parte do exercício. A fase CLEANUP declarada no registo, a apagar Event Logs, mostra ainda uma preocupação em simular comportamento anti-forense realista, o que tornou o cenário mais próximo de um incidente verdadeiro.

No fim, a lição que retiramos é dupla. Do lado técnico, ficámos mais à vontade com ferramentas como o Autopsy, o The Sleuth Kit, o foremost e o binwalk, e com a importância de confirmar cada achado por mais do que uma via. Do lado do

método, percebemos que investigar não é só encontrar ficheiros, mas construir uma narrativa sustentada em evidência, admitindo com honestidade aquilo que os dados não permitem afirmar.

12. Referências

- Haddad, W. (2021). *Practical Windows forensics: Experiments and forensic artifacts* (v1.0). Documento autopublicado.
- INTERPOL. (2021). *Guidelines for digital forensics first responders: Best practices for search and seizure of electronic and digital evidence*. Lyon: INTERPOL.
- International Organization for Standardization. (2012). *ISO/IEC 27037:2012 — Information technology, security techniques: Guidelines for identification, collection, acquisition and preservation of digital evidence*. Genebra: ISO/IEC.
- National Institute of Standards and Technology. (2006). *Guide to integrating forensic techniques into incident response* (NIST Special Publication 800-86). Gaithersburg, MD: NIST.
- Rede Nacional de CSIRT. (2023). *Taxonomia comum da Rede Nacional de CSIRT* (v3.3). Lisboa: Centro Nacional de Cibersegurança.
- Rosa, I. R. D. (2025a). Dual-role group dynamics as a practical and inclusive framework for teaching digital forensic analysis: Think like a hacker and think like an investigator. *International Journal for Research in Applied Science & Engineering Technology*, 13(12), 1386–1393. <https://doi.org/10.22214/ijraset.2025.76050>
- Rosa, I. R. D. (2025b). *Análise forense digital* [Material didático não publicado]. Curso Técnico Superior Profissional em Cibersegurança, ISTE — Instituto Superior de Tecnologias Avançadas.

13. Identificação

David Miranda — n.^o